

บทที่ 2

ทฤษฎีที่เกี่ยวข้อง

ปัจจุบันนี้การใช้ระบบเครือข่ายคอมพิวเตอร์กำลังเป็นที่นิยมกันอย่างกว้างขวาง ในองค์กรหรือหน่วยงานต่างๆ ระบบเครือข่ายคอมพิวเตอร์ที่มีใช้อยู่กันเป็นที่แพร่หลายมีอยู่สองประเภทใหญ่ๆ คือระบบเครือข่ายบริเวณเฉพาะที่ (Local Area Network หรือ LAN) และ ระบบเครือข่ายบริเวณกว้าง (Wide Area Network หรือ WAN) ซึ่งส่วนมากจะนิยมใช้สายเคเบิลแบบ UTP CAT5 (Unshielded Twisted Pair Category 5) ในการเชื่อมโยงคอมพิวเตอร์เข้าด้วยกัน แต่แนวโน้มในการพัฒนาเทคโนโลยี ทางด้านเครือข่ายเป็นไปอย่างรวดเร็วและไม่หยุดยั้ง ในปัจจุบันได้มีสื่อใหม่ที่เชื่อมโยงคอมพิวเตอร์เข้าด้วยกันโดยไม่ใช้สายเคเบิล หรือที่เรียกกันว่า ระบบเครือข่ายไร้สาย (Wireless LAN) เป็นเทคโนโลยีที่กำลังได้รับความนิยมและเป็นเป้าหมายที่น่าสนใจเป็นอย่างมากในยุคนี้

2.1 ความรู้เบื้องต้นเกี่ยวกับมาตรฐาน IEEE 802.11

มาตรฐาน IEEE 802.11 ซึ่งได้รับการตีพิมพ์ครั้งแรกเมื่อปี พ.ศ. 2540 โดย IEEE (The Institute of Electronics and Electrical Engineers) และเป็นเทคโนโลยีสำหรับ WLAN ที่นิยมใช้กันอย่างแพร่หลายมากที่สุด คือข้อกำหนด (Specification) สำหรับอุปกรณ์ WLAN ในส่วนของ Physical (PHY) Layer และ Media Access Control (MAC) Layer โดยในส่วนของ PHY Layer มาตรฐาน IEEE 802.11 ได้กำหนดให้อุปกรณ์มีความสามารถในการรับส่งข้อมูลด้วยความเร็ว 1, 2, 5.5, 11 และ 54 Mbps โดยมีสื่อ 3 ประเภทให้เลือกใช้ได้แก่ คลื่นวิทยุที่มีความถี่สาธารณะ 2.4 และ 5 GHz, และ อินฟราเรด (Infrared) (1 และ 2 Mbps เท่านั้น) สำหรับในส่วนของ MAC Layer มาตรฐาน IEEE 802.11 ได้กำหนดให้มีกลไกการทำงานที่เรียกว่า CSMA/CA (Carrier Sense Multiple Access/Collision Avoidance) ซึ่งมีความคล้ายคลึงกับหลักการ CSMA/CD (Collision Detection) ของมาตรฐาน IEEE 802.3 Ethernet ซึ่งเป็นที่นิยมใช้กันทั่วไปในเครือข่าย LAN แบบใช้สายนำสัญญาณ นอกจากนี้ในมาตรฐาน IEEE802.11 ยังกำหนดให้มีทางเลือกสำหรับสร้างความปลอดภัยให้กับเครือข่าย IEEE 802.11 WLAN โดยกลไกการเข้ารหัสข้อมูล (Encryption) และการตรวจสอบผู้ใช้ (Authentication) ที่มีชื่อเรียกว่า WEP (Wired Equivalent Privacy) ด้วย

มาตรฐาน IEEE 802.11

- IEEE 802.11b

คณะทำงานชุด IEEE 802.11b ได้ตีพิมพ์มาตรฐานเพิ่มเติมเมื่อปี พ.ศ. 2542 ซึ่งเป็นที่รู้จักกันดีและใช้งานกันอย่างแพร่หลายมากที่สุด มาตรฐาน IEEE 802.11b ใช้เทคโนโลยีที่เรียกว่า CCK (Complimentary Code Keying) ผสมกับ DSSS (Direct Sequence Spread Spectrum) เพื่อปรับปรุงความสามารถของอุปกรณ์ให้รับส่งข้อมูลได้ด้วยความเร็วสูงสุดที่ 11 Mbps ผ่านคลื่นวิทยุความถี่ 2.4 GHz (เป็นย่านความถี่ที่เรียกว่า ISM (Industrial Scientific and Medical) ซึ่งถูกจัดสรรไว้อย่างสากลสำหรับการใช้งานอย่างสาธารณะด้านวิทยาศาสตร์ อุตสาหกรรม และการแพทย์ โดยอุปกรณ์ที่ใช้ความถี่ย่านนี้ก็เช่น IEEE 802.11, Bluetooth, โทรศัพท์ไร้สาย, และเตาไมโครเวฟ) ส่วนใหญ่แล้วอุปกรณ์ IEEE 802.11 WLAN ที่ใช้กันอยู่ในปัจจุบันจะเป็นอุปกรณ์ตามมาตรฐาน IEEE 802.11b นี้และใช้เครื่องหมายการค้าที่รู้จักกันดีในนาม Wi-Fi ซึ่งเครื่องหมายการค้าดังกล่าวถูกกำหนดขึ้นโดยสมาคม WECA (Wireless Ethernet Compatibility Alliance) โดยอุปกรณ์ที่ได้รับเครื่องหมายการค้าดังกล่าวได้ผ่านการตรวจสอบแล้วว่าเป็นไปตามมาตรฐาน IEEE 802.11b และสามารถนำไปใช้งานร่วมกับอุปกรณ์ยี่ห้ออื่นๆที่ได้รับเครื่องหมาย Wi-Fi ได้

- IEEE 802.11a

คณะทำงานชุด IEEE 802.11a ได้ตีพิมพ์มาตรฐานเพิ่มเติมเมื่อปี พ.ศ. 2542 มาตรฐาน IEEE 802.11a ใช้เทคโนโลยีที่เรียกว่า OFDM (Orthogonal Frequency Division Multiplexing) เพื่อปรับปรุงความสามารถของอุปกรณ์ให้รับส่งข้อมูลได้ด้วยความเร็วสูงสุดที่ 54 Mbps แต่จะใช้คลื่นวิทยุที่ความถี่ 5 GHz ซึ่งเป็นย่านความถี่สาธารณะสำหรับใช้งานในประเทศสหรัฐอเมริกาที่มีสัญญาณรบกวนจากอุปกรณ์อื่นน้อยกว่าในย่านความถี่ 2.4 GHz อย่างไรก็ตามข้อเสียหนึ่งของมาตรฐาน IEEE 802.11a ที่ใช้คลื่นวิทยุที่ความถี่ 5 GHz ก็คือในบางประเทศย่านความถี่ดังกล่าวไม่สามารถนำมาใช้งานได้อย่างสาธารณะ ตัวอย่างเช่น ประเทศไทยไม่อนุญาตให้มีการใช้งานอุปกรณ์ IEEE 802.11a เนื่องจากความถี่ย่าน 5 GHz ได้ถูกจัดสรรสำหรับกิจการอื่นอยู่ก่อนแล้ว นอกจากนี้ข้อเสียอีกอย่างหนึ่งของอุปกรณ์ IEEE 802.11a WLAN ก็คือรัศมีของสัญญาณมีขนาดเล็กค่อนข้างสั้น (ประมาณ 30 เมตร ซึ่งสั้นกว่ารัศมีสัญญาณของอุปกรณ์ IEEE 802.11b WLAN ที่มีขนาดประมาณ 100 เมตร สำหรับการใช้งานภายในอาคาร) อีกทั้งอุปกรณ์ IEEE 802.11a WLAN ยังมีราคาสูงกว่า IEEE 802.11b WLAN ด้วย ดังนั้นอุปกรณ์ IEEE 802.11a WLAN จึงได้รับความนิยมน้อยกว่า IEEE 802.11b WLAN มาก

- IEEE 802.11g

คณะทำงานชุด IEEE 802.11g ได้ใช้นาเทคโนโลยี OFDM มาประยุกต์ใช้ในช่องสัญญาณวิทยุความถี่ 2.4 GHz ซึ่งอุปกรณ์ IEEE 802.11g WLAN มีความสามารถในการรับส่งข้อมูลด้วยความเร็วสูงสุดที่ 54 Mbps ส่วนรัศมีสัญญาณของอุปกรณ์ IEEE 802.11g WLAN จะอยู่ระหว่างรัศมีสัญญาณของอุปกรณ์ IEEE 802.11a และ IEEE 802.11b เนื่องจากความถี่ 2.4 GHz เป็นย่านความถี่สาธารณะสากล อีกทั้งอุปกรณ์ IEEE 802.11g WLAN สามารถทำงานร่วมกับอุปกรณ์ IEEE 802.11b WLAN

ได้ (backward-compatible) ดังนั้นจึงมีแนวโน้มสูงกว่าอุปกรณ์ IEEE 802.11g WLAN จะได้รับความนิยมอย่างแพร่หลายหากมีราคาไม่แพงจนเกินไปและน่าจะมาแทนที่ IEEE 802.11b ในที่สุด

2.2 ความรู้เบื้องต้นเกี่ยวกับการพิสูจน์ตัวตน

2.2.1 นิยามความมั่นคงปลอดภัยคอมพิวเตอร์

จุดประสงค์หลักของความปลอดภัยทางข้อมูลคือ ความลับ (Confidentiality) ความสมบูรณ์ (Integrity) ความพร้อมใช้ (Availability) และการห้ามปฏิเสธความรับผิดชอบ (Non-Repudiation) ของข้อมูลต่างๆภายในองค์กร (CIA-N) โดยมีรายละเอียดดังนี้

- **การรักษาความลับ (Confidentiality)** คือการรับรองว่าจะมีการเก็บข้อมูลไว้เป็นความลับ และผู้มีสิทธิเท่านั้นจึงจะเข้าถึงข้อมูลนั้นได้
- **การรักษาความสมบูรณ์ (Integrity)** คือการรับรองว่าข้อมูลจะไม่ถูกเปลี่ยนแปลงหรือทำลายไม่ว่าจะเป็นโดย อุบัติเหตุหรือโดยเจตนา
- **ความพร้อมใช้ (Availability)** คือการรับรองว่าข้อมูลและบริการการสื่อสารต่าง ๆ พร้อมที่จะใช้ได้ในเวลาที่ต้องการใช้งาน
- **การห้ามปฏิเสธความรับผิดชอบ (Non-Repudiation)** คือวิธีการสื่อสารซึ่งผู้ส่งข้อมูลได้รับหลักฐานว่าได้มีการส่งข้อมูลแล้วและผู้รับก็ได้รับการยืนยันว่าผู้ส่งเป็นใคร ดังนั้นทั้งผู้ส่งและผู้รับจะไม่สามารถปฏิเสธได้ว่าไม่มีความเกี่ยวข้องกับข้อมูลดังกล่าวในภายหลัง

ในทางปฏิบัตินั้นสามารถกำหนดลักษณะของการควบคุมความมั่นคงปลอดภัย (Security Controls) ได้ 5 ระดับตามรูป



รูปที่ 2.1 Security Pyramid

และถือเป็นองค์ประกอบที่สำคัญส่วนหนึ่งของความมั่นคงปลอดภัยคอมพิวเตอร์ เพราะจัดเป็นการกำหนดและควบคุมทั้งบุคคลที่สามารถเข้าสู่ระบบและเข้าสู่ข้อมูลภายในระบบ และเพื่อกระทำการใดได้บ้าง อนุญาตตามระดับชั้นของสำคัญของข้อมูล รวมไปถึงการจัดเก็บพฤติกรรมการใช้งานระบบของบุคคลนั้นต่อข้อมูลบนระบบทั้งหมด

2.2.2 วิธีการพิสูจน์ตัวตน

ในระบบเครือข่ายแบบเปิดหรืออินเทอร์เน็ต การพิสูจน์ตัวตนถือว่าเป็นกระบวนการเริ่มต้นและมีความสำคัญที่สุดในการปกป้องเครือข่ายให้ปลอดภัย โพรโตคอลในการพิสูจน์ตัวตนคือโพรโตคอลการสื่อสารที่มีกระบวนการพิสูจน์ตัวตนรวมอยู่ในชุดโพรโตคอล

Secure Socket Layer (SSL)

ในปัจจุบัน ผู้ใช้เครือข่ายอินเทอร์เน็ตมีจำนวนเพิ่มขึ้นอย่างมาก และเครือข่ายนี้ถูกใช้งานในรูปแบบต่างๆ มากมายหลายรูปแบบ โดยเฉพาะอย่างยิ่งในการพาณิชย์อิเล็กทรอนิกส์ (e-commerce) ซึ่งผู้ซื้อและผู้ขายจะต้องส่งข้อมูลที่เป็นความลับถึงกันและกัน เช่น ผู้ซื้อส่งหมายเลขบัตรเครดิตหรือที่อยู่และเบอร์โทรศัพท์โดยส่งผ่านไบนารีเครือข่าย อินเทอร์เน็ต หากข้อมูลเหล่านี้ถูกส่งไปแบบธรรมดาจะเป็นการค่อนข้างง่ายที่ผู้ไม่หวังดีจะสามารถดักจับข้อมูลเหล่านี้ (sniffing) แล้วนำไปใช้ได้ เนื่องจากข้อมูลเหล่านี้อยู่ในรูปของข้อมูลที่ไม่ได้มีการเข้ารหัส ผู้ดักจับข้อมูลก็จะสามารถนำข้อมูลนั้นไปใช้ได้ทันที

ในอีกกรณีหนึ่ง บนเครือข่ายอินเทอร์เน็ตนี้ ผู้ใช้สามารถเชื่อมต่อและใช้งานเครื่องคอมพิวเตอร์ใดๆ ก็ได้หากผู้ใช้นั้นได้รับอนุญาตและสามารถพิสูจน์ตนเองโดยใช้ ชื่อผู้ใช้ และรหัสผ่าน ที่ถูกต้องบนเครื่องนั้นๆ โดยจะมีโปรแกรมที่ช่วยในการเชื่อมต่อและใช้งานนั้น เช่น telnet, rsh, rlogin, rcp และ ftp เป็นต้น โปรแกรมเหล่านี้ส่งข้อมูลตามแบบมาตรฐานดั้งเดิมของเครือข่ายอินเทอร์เน็ต กล่าวคือ ส่งข้อมูลทุกอย่าง (รวมทั้ง ชื่อผู้ใช้ และรหัสผ่าน) ในรูปของ ข้อมูลที่ไม่ได้เข้ารหัส ดังนั้นหากมีผู้ดักจับข้อมูลเกี่ยวกับ ชื่อผู้ใช้ และ รหัสผ่านได้ ผู้นั้นก็จะสามารถนำเอา ชื่อผู้ใช้ และรหัสผ่าน นี้ไปใช้ในการเชื่อมต่อและใช้งานเครื่องคอมพิวเตอร์เครื่องนั้นได้ต่อไป

เนื่องจากปัญหาที่กล่าวมานี้เป็นปัญหาที่ค่อนข้างใหญ่ เพราะการดักจับข้อมูลนั้นสามารถกระทำได้อย่างค่อนข้างง่าย จึงได้มีการคิดแก้ไขปัญหานี้ขึ้นโดย Netscape ได้คิดค้น โพรโตคอลใหม่ขึ้นมาคือ Secure Socket Layer Protocol (SSL) และโปรแกรมเมอร์ชาว Finland ได้เขียนโปรแกรมขึ้นชุดหนึ่ง เรียกว่า Secure Shell (SSH) ซึ่งทั้ง SSL และ SSH จะเข้ารหัสลับข้อมูลใดๆ ก่อนที่ข้อมูลนั้นจะถูกส่งไปบนเครือข่ายอินเทอร์เน็ต ดังนั้นหากผู้ไม่หวังดีสามารถดักจับข้อมูลนั้นไปได้ ผู้นั้นก็ไม่สามารถที่จะนำข้อมูลนั้นไปใช้ได้ เพราะเขาไม่สามารถตีความข้อมูลนั้นได้

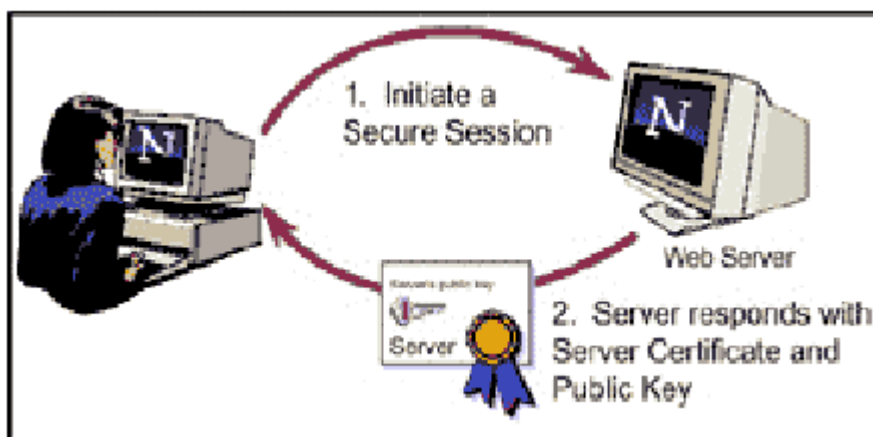
SSL นั้นได้รับการยอมรับอย่างกว้างขวางบน เวิลด์ ไวด์ เว็บ (WWW) ในการใช้สำหรับตรวจสอบ และเข้ารหัสลับการติดต่อสื่อสารระหว่าง เครื่องลูกข่าย และเครื่องแม่ข่าย หน้าที่ของ SSL จะแบ่งออกเป็น 3 ส่วนใหญ่ๆ คือ

1. การตรวจสอบเครื่องแม่ข่ายว่าเป็นตัวจริง: ตัวโปรแกรมเครื่องลูกข่ายที่มีขีดความสามารถในการสื่อสารแบบ SSL จะสามารถตรวจสอบเครื่องแม่ข่าย ที่ตนกำลังจะไปเชื่อมต่อได้ว่าเครื่องแม่ข่ายนั้นเป็นเครื่องแม่ข่ายตัวจริงหรือไม่ โดยใช้เทคนิคการเข้ารหัสแบบ อนุกรม

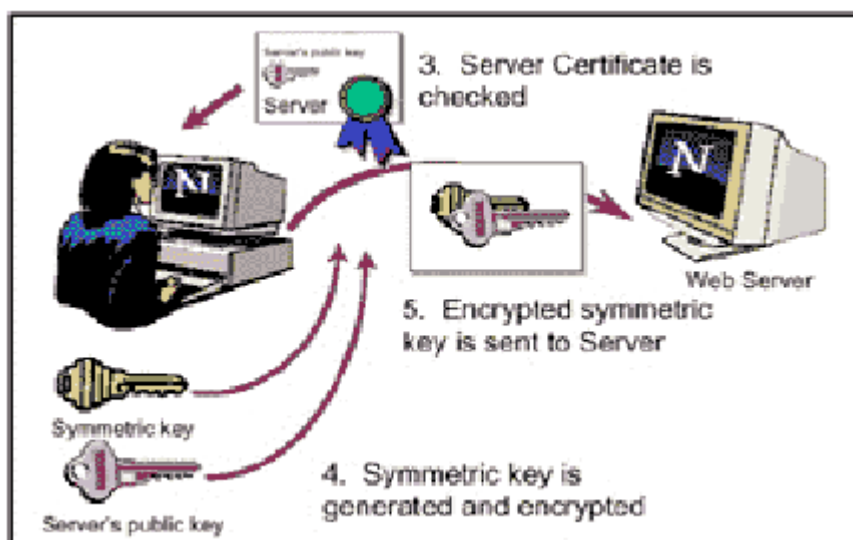
สาธารณะ ในการตรวจสอบใบรับรอง (certificate) และ ID สาธารณะของเครื่องแม่ข่ายนั้น (โดยที่มีองค์กรที่เครื่องลูกข่ายเชื่อถือเป็นผู้ออกใบรับรองและ ID สาธารณะให้แก่ เครื่องแม่ข่ายนั้น) หน้าที่นี้ของ SSL เป็นหน้าที่ที่สำคัญ โดยเฉพาะอย่างยิ่งในกรณีที่ เครื่องลูกข่ายต้องการที่จะส่งข้อมูลที่เป็นความลับ (เช่น หมายเลขบัตรเครดิต) ให้กับเครื่องแม่ข่าย ซึ่งเครื่องลูกข่ายจะต้องตรวจสอบก่อนว่าเครื่องแม่ข่ายเป็นความจริงหรือไม่

2. การตรวจสอบว่าเครื่องลูกข่ายเป็นความจริง: เครื่องแม่ข่ายที่มีขีดความสามารถในการสื่อสารแบบ SSL จะใช้เทคนิคเช่นเดียวกับในหัวข้อที่แล้วในการตรวจสอบเครื่องลูกข่าย หรือผู้ใช้งานว่าเป็นความจริงหรือไม่ โดยจะตรวจสอบใบรับรอง และ ID สาธารณะ (ที่มีองค์กรที่ เครื่องแม่ข่ายเชื่อถือเป็นผู้ออกให้) ของเครื่องลูกข่าย หรือผู้ใช้นั้น หน้าที่นี้ของ SSL จะมีประโยชน์ในกรณีเช่นธนาคารต้องการที่จะส่งข้อมูลลับทางการเงินให้แก่ลูกค้าของตนผ่านทางเครือข่ายอินเทอร์เน็ต (เครื่องแม่ข่าย ก็จะต้องตรวจสอบ เครื่องลูกข่ายก่อนว่าเป็น เครื่องลูกข่าย นั้นจริง)

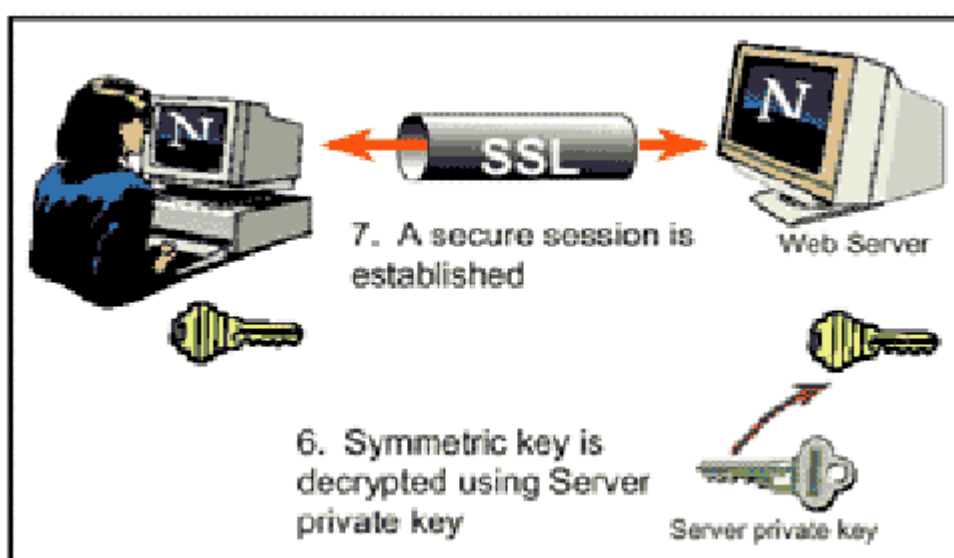
3. การเข้ารหัสลับการเชื่อมต่อ: ในกรณีนี้ ข้อมูลทั้งหมดที่ถูกส่งระหว่างเครื่องลูกข่าย และเครื่องแม่ข่าย จะถูกเข้ารหัสลับ โดยโปรแกรมที่ส่งข้อมูลเป็นผู้เข้ารหัส และโปรแกรมที่รับข้อมูลเป็นผู้ถอดรหัส (โดยใช้วิธี กุญแจสาธารณะ) นอกจากการเข้ารหัสลับในลักษณะนี้แล้ว SSL ยังสามารถปกป้องความถูกต้องสมบูรณ์ของข้อมูลได้อีกด้วย กล่าวคือ ตัวโปรแกรมรับข้อมูลจะทราบได้หากข้อมูลถูกเปลี่ยนแปลงไปในขณะกำลังเดินทางจากผู้ส่งไปยังผู้รับ



รูปที่ 2.2 ผู้ใช้คอมพิวเตอร์เริ่มกระบวนการติดต่อเซิร์ฟเวอร์ที่มี SSL และเซิร์ฟเวอร์ส่งใบรับรองที่ผ่านการเข้ารหัสกลับมา



รูปที่ 2.3 คอมพิวเตอร์ของผู้ใช้สร้างกุญแจสมมาตร และทำการเข้ารหัสกุญแจสมมาตรด้วยกุญแจสาธารณะของเซิร์ฟเวอร์ที่ได้รับมา



รูปที่ 2.4 เซิร์ฟเวอร์ถอดรหัสที่ได้รับด้วยกุญแจส่วนตัว และได้กุญแจสมมาตรของลูกค้าไว้ใช้

Radius Authentication and Authorization

RADIUS (Remote Access Dial-Up User Service) เป็นเทคโนโลยีมาตรฐานอีกอันหนึ่งซึ่งใช้กันมากในองค์กรเพื่อป้องกันการเข้าถึงเครือข่ายไร้สาย โดย RADIUS คือ โครงสร้าง ชื่อผู้ใช้ และรหัสผ่าน ซึ่งเป็นเฉพาะผู้ที่ได้รับการอนุญาตให้เข้าถึงเครือข่ายได้เท่านั้น ครั้งแรกที่ผู้ใช้งานต้องการเข้าถึงเครือข่าย, ไฟล์ที่ต้องการความปลอดภัย หรือ Net location เขาจะต้องใส่ ชื่อผู้ใช้ และรหัสผ่าน ส่งมันผ่านเครือข่าย ไปยัง RADIUS เครื่องแม่ข่าย เครื่องแม่ข่ายก็จะตรวจสอบข้อมูลผู้ใช้งาน และรหัสผ่าน ก่อนจึงยอมให้ผู้ใช้งานเข้าใช้เครือข่ายได้ RADIUS สามารถถูกติดตั้งเพื่อให้การเข้าถึงใน

ระดับที่ต่างกัน ตัวอย่างเช่น ระดับหนึ่งสามารถให้ใช้อินเทอร์เน็ตได้ อีกระดับให้ใช้อินเทอร์เน็ตและ อีเมลล์ได้ อีกระดับหนึ่งสามารถใช้อินเทอร์เน็ต อีเมลล์ และไฟล์ข้อมูลทางธุรกิจที่ต้องการความปลอดภัยได้

2.3 โครงสร้างของแอคทีฟไดเรกทอรี

Active Directory (AD) เป็นไดเรกทอรีเซอร์วิสในระดับองค์กร ที่ถูกออกแบบบนมาตรฐานของเทคโนโลยีอินเทอร์เน็ต เอาไว้รองรับการค้นหาทรัพยากรต่างๆ บนเครือข่ายขนาดใหญ่ และยังช่วยให้ผู้ดูแลระบบ จัดการบริหารเครือข่ายที่ซับซ้อนจากศูนย์กลางได้อย่างสะดวก AD เป็นการทำงานร่วมกันระหว่าง Domain Naming System (DNS) และ Lightweight Directory Access Protocol (LDAP) ทำให้สามารถติดต่อเชื่อมโยง (interoperability) กับไดเรกทอรีเซอร์วิสอื่นๆ ได้อีกด้วย และมีการพัฒนา Distributed Component Object Model (DCOM) ให้มีประสิทธิภาพในการกระจายแอปพลิเคชันได้ดียิ่งขึ้น AD จะมีโครงสร้างอยู่ 2 แบบคือ ทางกายภาพ (Physical Structure) และทางลอจิกอล (Logical Structure)

ไดเรกทอรีตัวอย่างที่เห็นอยู่ทั่วไป เช่น สมุดโทรศัพท์หน้าเหลือง ที่ใช้เก็บรวบรวมข้อมูลเกี่ยวกับรายชื่อ นามสกุล ที่อยู่ เบอร์โทร เมื่อเราต้องการจะค้นหาเบอร์โทรศัพท์ก็เพียงแค่เปิดไปยังหน้าที่มี ชื่อ-สกุลนั้นๆ สมุดโทรศัพท์จึงเป็นสิ่งที่รวบรวมข้อมูลต่างๆ ที่เกี่ยวกับผู้ใช้โทรศัพท์เอาไว้ AD ก็คล้ายกับสมุดโทรศัพท์แต่จะเก็บรวบรวมอ็อบเจกต์และทรัพยากรต่างๆ บนระบบเน็ตเวิร์กเอาไว้ (อ็อบเจกต์เหล่านี้คือ ยูสเซอร์ เครื่องพิมพ์ ไฟล์เอกสาร อีเมลแอคเคส) นอกจากนี้ AD ยังจัดเก็บคุณสมบัติ (Attributes) ของอ็อบเจกต์และทรัพยากรนั้นไว้เพื่อให้ยูสเซอร์สามารถเข้ามาค้นหาอ็อบเจกต์ที่ต้องการได้อย่างรวดเร็ว AD ประกอบด้วยการทำงาน 2 ส่วนด้วยกันคือ Active Directory Service และ Active Directory Database

Active Directory Service

เป็นการให้บริการแก่ Admin (ผู้บริหารระบบ) เช่น การสร้างหรือลบรายชื่อผู้ใช้ การเปลี่ยนรหัสผ่าน การกำหนดนโยบายของกลุ่ม (Group Policy) การสร้างแชร์โฟลเดอร์ การสร้างรายชื่อเครื่องคอมพิวเตอร์ การติดตั้งพริ้นเซอร์ฟเวอร์ ให้บริการในการค้นหาอ็อบเจกต์หรือทรัพยากรต่างๆ บนระบบเน็ตเวิร์ก Active Directory Service จะสนับสนุนทั้งโปรโตคอล DNS และ LDAP

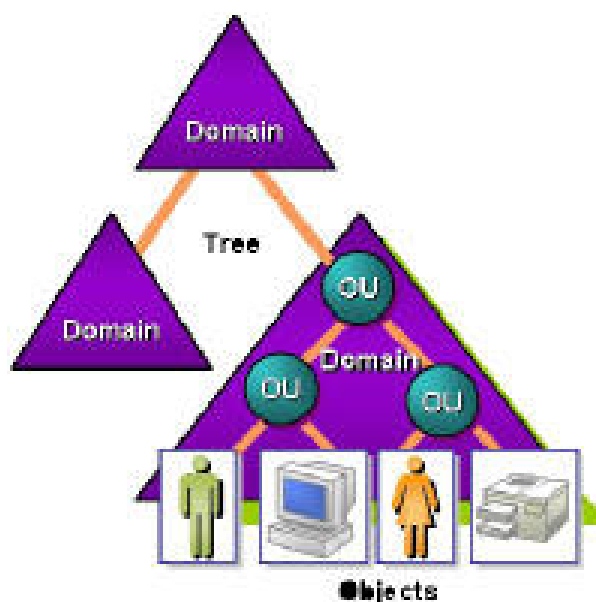
Active Directory Database

เป็นฐานข้อมูลในการจัดเก็บไดเรกทอรี(อ็อบเจกต์) บนระบบเน็ตเวิร์กไว้ เช่น บัญชีรายชื่อ และคุณลักษณะของผู้ใช้-กลุ่มผู้ใช้ รายชื่อ และคุณสมบัติของทรัพยากรต่างๆ (คอมพิวเตอร์ เครื่องพิมพ์ แชร์โฟลเดอร์) ในการจัดเก็บรายชื่อและคุณสมบัติของทรัพยากรบนระบบเน็ตเวิร์กไว้

ในฐานข้อมูล Active Directory จะช่วยให้ยูสเซอร์สามารถค้นหาและเรียกใช้ทรัพยากรนั้นได้ง่ายและรวดเร็วขึ้น

ส่วนประกอบของ Active Directory

Active Directory เป็นฐานข้อมูลแบบประสมที่ใช้เก็บรายละเอียดบัญชีรายชื่อ-คุณสมบัติผู้ใช้, กลุ่มผู้ใช้, คุณสมบัติของทรัพยากร และแอปพลิเคชัน โดยจะมองทรัพยากรเป็นเหมือนกับวัตถุ (Object) มี OU (Organization Unit) สำหรับเก็บอ็อบเจกต์ต่างเอาไว้ มีการจัดลำดับชั้น (Hierarchy) คล้ายๆ โครงสร้างแบบป่า-ต้นไม้ (Forest-Tree) ที่ใช้เก็บไฟล์-โฟลเดอร์ต่างๆ ฐานข้อมูลเหล่านี้จะอยู่บนเครื่อง Windows Server 2003 ที่เป็นโดเมนคอนโทรลเลอร์(Domain Controller)



รูปที่ 2.5 โครงสร้างพื้นฐานของโดเมนคอนโทรลเลอร์และ OU

จากรูปโดเมนของ Active Directory มีโครงสร้างเป็นลำดับชั้น (Hierarchy) แบบต้นไม้คือจากโดเมนหลัก จะถูกแบ่งชั้นลงมาเป็นโดเมนย่อย จากโดเมนย่อยลงมาเป็นหน่วยขององค์กร Organization Unit (OU) ซึ่งประกอบด้วยอ็อบเจกต์ต่างๆ (ผู้ใช้ เครื่องพิมพ์ กลุ่ม และ ทรัพยากรต่างๆ) และในองค์กรยังสามารถจะมีโดเมนหลัก (Tree) ได้มากกว่าหนึ่งโดเมน

อ็อบเจกต์ (Object) เป็นส่วนที่เล็กที่สุดของไดเรกทอรี อ็อบเจกต์จะรวมไปถึงยูสเซอร์แอคเคาน์ เซิร์ฟเวอร์ เครื่องพิมพ์ กลุ่มยูสเซอร์ ซึ่งอ็อบเจกต์แต่ละตัวจะมีแอตทริบิวต์ (Attribute) ในการแสดงคุณสมบัติของอ็อบเจกต์นั้นๆ เช่น อ็อบเจกต์ยูสเซอร์แอคเคาน์จะมีแอตทริบิวต์เป็น Name, Last Name, E-mail

คลาส (Class) เป็นตัวแบ่งประเภทของอ็อบเจกต์ บนฐานข้อมูล AD จะมีดีฟอลต์คลาสที่ถูกสร้างขึ้นในการติดตั้ง AD เช่น Built in, Computers, Domain Controller, Foreign Security Principals และ Users ในการสร้างรายชื่อยูสเซอร์ขึ้นมาจะถูกเก็บไว้ในคลาส Users ส่วนรายชื่อเครื่องคอมพิวเตอร์จะถูกเก็บไว้ในคลาส Computers หมายความว่าอ็อบเจกต์แต่ละตัวจะต้องถูกเก็บไว้ในคลาสของตัวเอง

แอตทริบิวต์ (Attributes) เป็นตัวที่ใช้บอกถึงคุณสมบัติ คุณลักษณะ และพฤติกรรมของอ็อบเจกต์กล่าวคือ อ็อบเจกต์แต่ละตัวจะมีแอตทริบิวต์ที่แตกต่างกัน แต่อ็อบเจกต์ที่อยู่ในคลาสเดียวกันจะมีแอตทริบิวต์ที่เหมือนกันเช่น อ็อบเจกต์ในคลาส Users จะมีแอตทริบิวต์ Name, Last Name, Logon Name, รหัสผ่าน, E-mail, Telephone etc. แต่ละอ็อบเจกต์ของยูสเซอร์แอคเคาน์จะมีค่า(Value) หรือค่าของแอตทริบิวต์ต่างกัน เช่น อ็อบเจกต์หนึ่งมีค่าแอตทริบิวต์ Logon Name เป็น chawalit จะเป็นการบอกให้ทราบว่าอ็อบเจกต์นี้เป็นตัวแทนของยูสเซอร์ chawalit sapsatitkul ซึ่งจะมีค่าแอตทริบิวต์ Logon Name ไม่ซ้ำกับอ็อบเจกต์ตัวอื่นๆ

Organization Unit (OU) เป็นเสมือนดังคอนเทนเนอร์ (Container) ในการเก็บอ็อบเจกต์ต่างไว้ในตามลำดับ OU จะมีโครงสร้างเป็นลำดับชั้น (Hierarchy) ทำให้สามารถสร้าง OU ย่อยลงไปได้อีก OU ยังช่วยแบ่งเบาภาระในการทำงานได้อีกด้วย เช่น ถ้าต้องการกำหนดนโยบายต่างๆ ให้กับอ็อบเจกต์แบบ Users, Computers ก็ให้กำหนดนโยบายนั้นผ่าน OU ที่อ็อบเจกต์เหล่านั้นอยู่ภายในเพียงครั้งเดียวเท่านั้น ทำให้ไม่ต้องเสียเวลาไปกำหนดทีละตัว

โดเมน (Domain) เป็นที่รวมของทรัพยากรบนระบบเน็ตเวิร์กเอาไว้ทั้งหมด เช่น ยูสเซอร์ เครื่องคอมพิวเตอร์ เครื่องเซิร์ฟเวอร์ เครื่องพิมพ์ เซิร์ฟโพลเดอร์ และอ็อบเจกต์อื่นๆ ไว้ด้วยกัน ภายใต้ชื่อโดเมนนั้นจะต้องมีฐานข้อมูลส่วนกลางที่ใช้เก็บรายละเอียดต่างๆ ของแอคเคาน์ และทรัพยากรต่างๆ เอาไว้

2.4 Lightweight Directory Access Protocol (LDAP)

LDAP คืออะไร

LDAP (นิยามอ่านว่า "แอล-แด้บ") เป็นโปรโตคอลที่พัฒนามาจาก โปรโตคอล X.500 ซึ่งใช้ในการเข้าถึงและ Update ข้อมูลของไดเรกทอรี ซึ่งไดเรกทอรีในทางคอมพิวเตอร์ที่จริงก็อาจเรียกได้ว่าเป็น ดาต้าเบสแบบพิเศษ หรือ Data repository ที่บรรจุรายละเอียดของอ็อบเจกต์ต่างๆ เช่น Users, Application, Files, Printer และอื่นๆ รวมทั้ง Security information ของอ็อบเจกต์เหล่านี้ด้วย โดยข้อแตกต่างของ ไดเรกทอรี กับ ดาต้าเบสปกติ ได้แก่

1. Operation: ใน ไดเรกทอรีจะเน้นที่การ Access ข้อมูลหรือ อ่านข้อมูล มากกว่า Update

- หรือ เขียนข้อมูล ในขณะที่ คาด้าเบส ทั่วไปจะเน้นการ Update มากกว่า
2. Transaction: ใน คาด้าเบส จะรองรับการทำ Transaction หรือการ Update ข้อมูลสองจุดที่ต้องสอดคล้องกัน แบบ All-or-nothing เช่นการโอนเงินจากบัญชีหนึ่ง ไปอีกบัญชีหนึ่ง ที่ต้องการความสมบูรณ์ทั้ง 2 ฝั่ง หรือไม่ก็ต้องทำเลย ในขณะที่ ไคลเอนต์ ที่เน้นการอ่านอย่างเดียว อาจจะไม่ต้องการความสอดคล้องกันของข้อมูลบ้างนัก เช่นเมื่อมีการย้ายที่อยู่ระหว่างคน 2 คน ก็ต้องมีการปรับเปลี่ยนเบอร์ติดต่อของ 2 คนนั้น ซึ่งตรงนี้อาจจะไม่จำเป็นต้องทำทันที อย่างไรก็ตาม Feature นี้ อาจจะมีการผนวกเข้ากับ LDAP Product ใหม่ๆ ในอนาคตก็ได้
 3. Data Accuracy: ไคลเอนต์ อาจจะมีข้อจำกัดในการจัดเก็บข้อมูลที่ไม่สมบูรณ์ เช่นมีแต่ชื่อ ไม่มีที่อยู่ แต่อย่างไรก็ตาม เราสามารถ Configure คุณสมบัติเหล่านี้ได้ในบาง Directory Service
 4. Query: Directory ไม่ Support Query String (SQL, Structured Query Language)

อย่างไรก็ตามถึงแม้ไคลเอนต์จะมีคุณสมบัติด้อยกว่าคาด้าเบสหลายประการ แต่เนื่องจากโปรโตคอลที่ใช้ในการเข้าถึงไคลเอนต์ เช่น LDAP มีความเร็วในการเข้าถึงข้อมูลสูง และก็ทำให้ Application ที่ทำงานบนโปรโตคอลเหล่านี้สามารถเข้าถึงข้อมูลอย่างรวดเร็ว ทำให้ระบบไคลเอนต์เป็นที่ยอมรับ และนำมาใช้งานทั่วไป

นอกจากประโยชน์ในการค้นหาข้อมูลได้อย่างรวดเร็วแล้ว ไคลเอนต์ยังเป็นโครงสร้างข้อมูลที่แสดงให้เห็นข้อมูลทั้งหมดได้จากมุมมองเดียว (Single Logical View) แม้ว่าแท้จริงแล้วข้อมูลเหล่านั้นอาจถูกเก็บแยกกันอยู่อย่างกระจัดกระจายตาม Host ต่างๆ บนระบบแบบกระจาย (Distributed System) ซึ่งข้อดีต่างๆ เหล่านี้ ทำให้มีการพัฒนา Application ที่ใช้ Directory Service ออกมามากมาย และ LDAP ก็คือหนึ่งในมาตรฐานที่ใช้จัดการ การรับส่งข้อมูลระหว่าง Application เครื่องแม่ข่าย ที่เก็บไคลเอนต์ เหล่านี้ กับ เครื่องลูกข่าย Application ที่เป็นฝ่ายเรียกดูข้อมูลจาก ไคลเอนต์

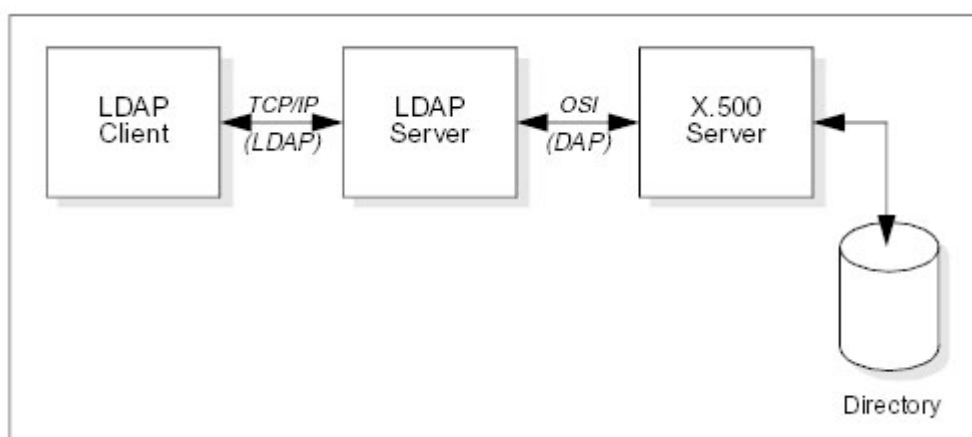
อีกหนึ่งสาเหตุที่จำเป็นต้องมีมาตรฐานในการเข้าถึงข้อมูลในไคลเอนต์นั้นก็เพื่อ ให้การพัฒนา Application ที่ใช้ติดต่อกับไคลเอนต์ เครื่องแม่ข่าย นั้นมีความยืดหยุ่นขึ้น โดย Developer สามารถเรียกใช้ Application Programming Interface (API) เพื่อติดต่อกับ Directory Service ได้โดยไม่ต้องทราบวิธีการเข้าถึงโดยละเอียด เช่นโครงสร้างไคลเอนต์ หรือ ชนิดของข้อมูล (Data Type) ภายใน หรือไม่จำเป็นต้องปรับแก้ Application ใหม่หากมีความต้องการชนิดข้อมูลใหม่ๆ เป็นต้น

นอกเหนือจากที่กล่าวมาข้างต้นแล้ว การมีมาตรฐานเดียวกัน ทำให้ผู้ผลิต Application และ Network device ที่รองรับการใช้งาน Directory Service มีระเบียบวิธีที่ชัดเจนเป็นกลาง ทำให้การ

ติดต่อระหว่าง Application จากต่างผู้ผลิต หรือต่าง Platform นั้นเป็นไปได้อย่างรวดเร็ว ถูกต้อง และปลอดภัย โดยไม่ต้องทราบข้อมูลที่ใช้ในการติดต่อ เช่น Platform ที่ใช้, Host Name หรือ IP address เช่นเดียวกับการที่เราต้องมี TCI/IP, HTTP, FTP, RPC หรือ ORB เป็นมาตรฐานที่ใช้อยู่ทั่วโลก

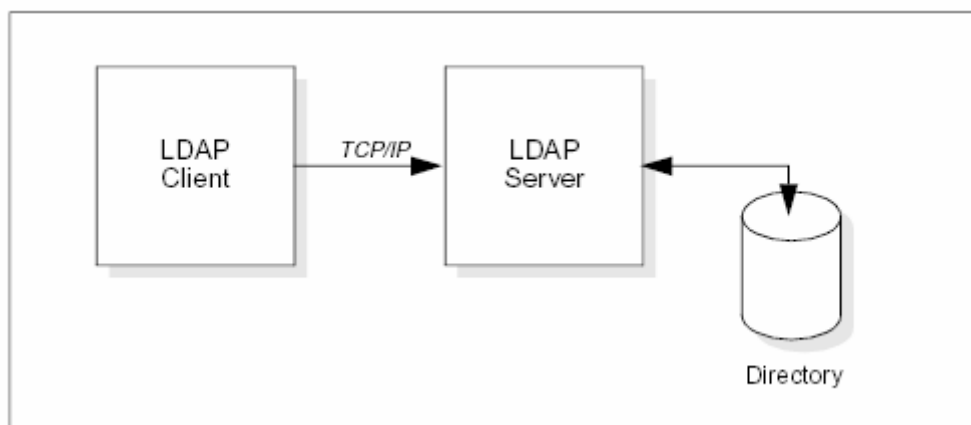
LDAP เป็นมาตรฐานที่ได้รับการยอมรับอย่างกว้างขวาง และมี Application Vendor อยู่หลายราย อาทิ OpenLDAP, IBM, Oracle, Microsoft ซึ่ง Product ที่ได้รับความนิยมก็ได้แก่ Slapd ของ University of Michigan และ Openldap, Directory Server ของ Netscape, Active Directory (AD) ของ Microsoft, Novell Directory Services (NDS) ของ Novell, Sun Directory Services (SDS) ของ Sun และ Internet Directory Server (IDS) ของ Lucent

LDAP ได้รับการออกแบบมาให้อยู่บน TCP/IP Layer ที่มีเพียง 4 Layer ทำให้มีความต้องการทรัพยากรน้อยกว่า DAP ของมาตรฐาน X.500 อย่างไรก็ดีตาม หากมีความต้องการติดต่อกันระหว่าง LDAP เครื่องลูกข่าย กับ X.500 เครื่องแม่ข่าย จำเป็นจะต้องมีการติดต่อผ่านเกตเวย์ ที่เรียกว่า LDAP เซิร์ฟเวอร์ ตามรูป



รูปที่ 2.6 การติดต่อกันระหว่าง LDAP เครื่องลูกข่าย กับ X.500 เครื่องแม่ข่าย

จากภาพจะเห็นได้ว่า LDAP เครื่องแม่ข่ายจะต้องมีความเข้าใจทั้ง TCP/IP และ OSI Model ในขณะที่ตัว LDAP เครื่องลูกข่ายไม่จำเป็นต้องทำความเข้าใจกับ OSI Layer และไม่ต้องประมวลผลตาม DAP ที่มีความซับซ้อน และ Overhead สูง สำหรับระบบที่ไม่มีการใช้ X.500 ก็สามารถมีเพียง LDAP เครื่องลูกข่าย กับ LDAP เครื่องแม่ข่าย ซึ่งเรียกว่า LDAP stand-alone server ตามรูปด้านล่าง



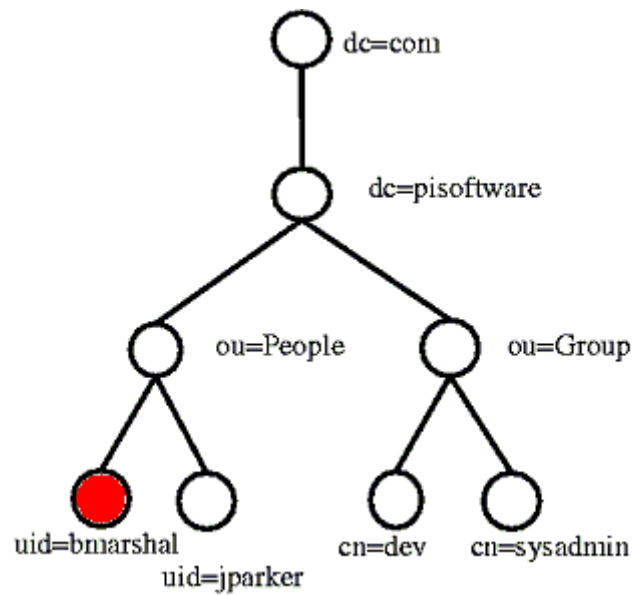
รูปที่ 2.7 การติดต่อแบบ LDAP stand-alone server

จากตัวอย่าง 2 ตัวอย่างข้างต้น ทำให้เราเห็นว่า จากมุมมองของเครื่องลูกข่ายแล้ว ไม่ว่าใคร่กทอริที่ติดต่อเข้าไปจะอยู่บน LDAP เครื่องแม่ข่าย หรือ X.500 เครื่องแม่ข่าย เครื่องลูกข่ายจะเรียกใคร่กทอริเหล่านั้นว่า LDAP Directory และเรียก เครื่องแม่ข่าย นั้นว่า LDAP Server

LDAP Directory มีการจัดโครงสร้างแบบลำดับชั้น (Hierarchical) โดยข้อมูลจะถูกบรรจุอยู่ใน Entries ซึ่งแต่ละ Entry จะประกอบด้วย Attribute ในรูปของ <type>=<value> โดย type จะถูกกำหนดไว้ด้วย Object Identifier (OID) ส่วน value ก็จะมี Syntax ที่ระบุไว้ชัดเจน

Entry จะถูกจัดไว้เป็นลำดับชั้นด้วย Distinguished name (DN) โดย Entry ใดๆ ที่อยู่ใต้ Entry อื่น จะมี DN ของ Entry อื่นเป็น Suffix (ข้อความที่ตามหลัง) Entry นั้น

Schema ของ Directory จะระบุ DN และระบุว่า แต่ละ Entry จะประกอบไปด้วย Attribute ใดบ้าง โดย Schema จะกำหนดข้อมูลเหล่านี้ไว้ใน Object class ซึ่งได้แก่ List ของ Mandatory กับ Optional Attribute, วิธีการเปรียบเทียบ Attribute, ชนิดและขนาดของข้อมูลที่อนุญาต ซึ่งทุกๆ Entry จะต้องเชื่อมโยงไว้กับ Object Class หนึ่ง Class



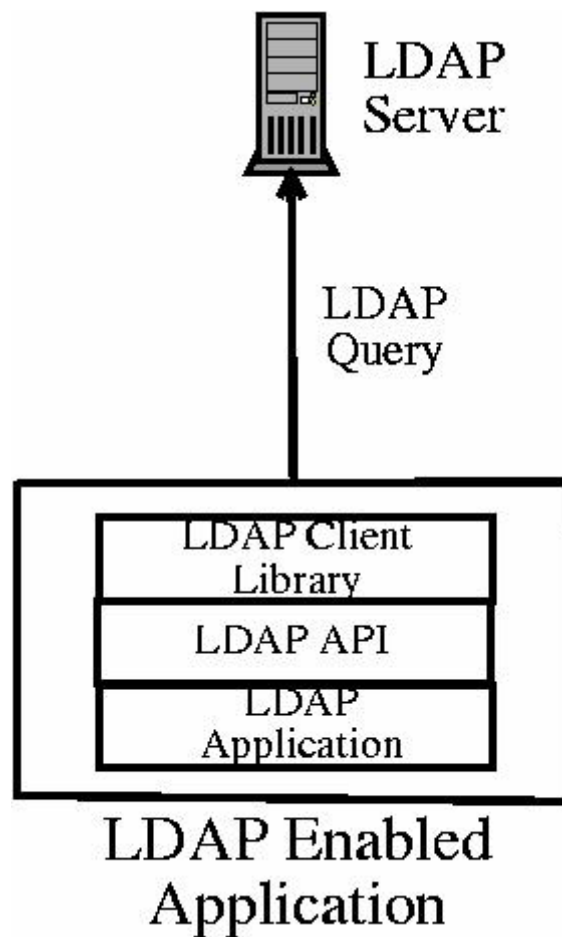
รูปที่ 2.8 โครงสร้าง Entry ของ Directory แบบ Hierarchy

จาก Hierarchy ของ Directory ด้านบน Entry ที่มีสีที่บ่งจะถูกระบุด้วย DN ดังนี้

dn: uid=bmarshal,ou=People,dc=piSoftware,dc=com

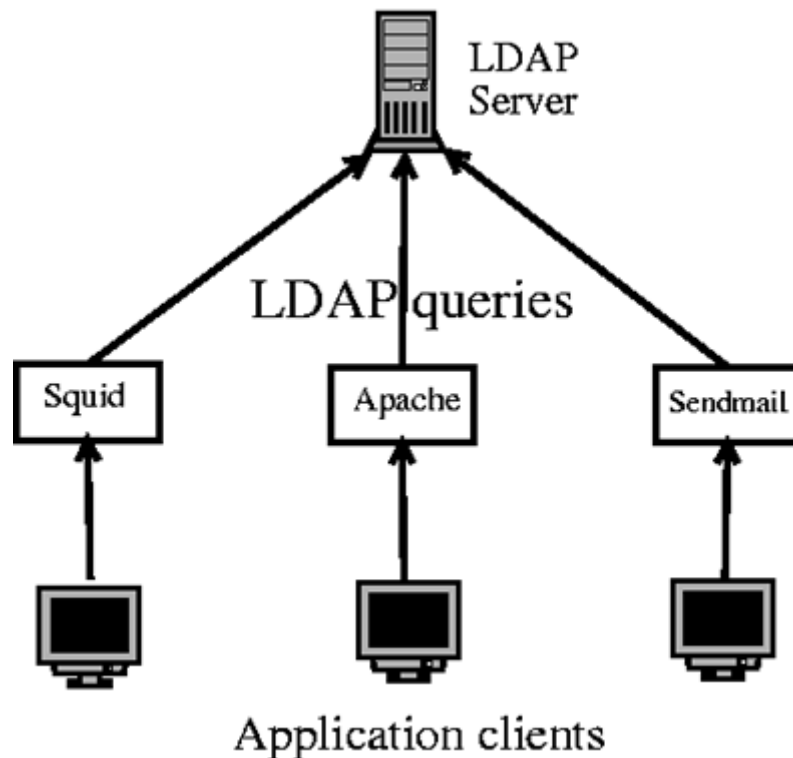
แอตทริบิวต์ส่วนใหญ่จะมีการใช้ตัวอักษรย่อระบุ type ซึ่งได้แก่ uid = User id, cn = Common Name, sn = Surname, l = Location, ou = Organizational Unit, o = Organization, dc = Domain Component, st = State, c = Country, etc. โดยข้อมูลเพิ่มเติมในส่วนนี้สามารถหาได้จาก (RFC2256)

โดยทั่วไป LDAP Application จะประกอบด้วย Layer ต่างๆดังภาพด้านล่าง



รูปที่ 2.9 Layer LDAP application

เนื่องจาก LDAP เป็นมาตรฐานที่ได้รับการยอมรับในหลายผู้ผลิต ดังนั้นการ Implement LDAP Application จึงนำไปประยุกต์ใช้ได้หลายๆ Application ดังภาพ



รูปที่ 2.10 การประยุกต์ LDAP ใช้งาน

การสร้างดาต้าเบส หรือไดเรกทอรี ด้วยการ เพิ่มอ็อบเจกต์ หรือ เอ็นทรี และ แอดทริบิวต์ ลงไปใน LDAP Database

2.4.1 การสร้างไดเรกทอรี

ในขณะที่ LDAP Service กำลังทำงานอยู่นั้น เราสามารถใช้ Command line ในการเพิ่มหรือลบ อ็อบเจกต์ หรือ เอ็นทรี ที่มีอยู่ได้ รวมไปถึงการเพิ่มแอดทริบิวต์ ใหม่ๆ หรือแก้ไขแอดทริบิวต์เดิม คำสั่งในการเพิ่ม อ็อบเจกต์ หรือ เอ็นทรี ใหม่รวมทั้ง แอดทริบิวต์ของอ็อบเจกต์ หรือ เอ็นทรี นั้น คือ 'ldapadd' ส่วนคำสั่งในการแก้ไข อ็อบเจกต์ และ แอดทริบิวต์ คือ 'ldapmodify'

LDAP security model

เป็นโมเดลของโครงสร้าง LDAPv3 ใช้กำหนดสิทธิในการใช้งานและการเข้าถึงข้อมูลของผู้ใช้หรือไคลเอนต์โดยที่การทำงานของ LDAP เครื่องแม่ข่าย และ LDAP เครื่องลูกข่าย นั้นจะทำงานในรูปแบบ connection-oriented โปรโตคอล กล่าวคือก่อนที่จะเริ่มทำการรับ-ส่งข้อมูลกันนั้น ไคลเอนต์จะทำการส่ง Operation bind เพื่อขอสิทธิการใช้งาน เมื่อ LDAP เครื่องแม่ข่าย ทำการตรวจสอบว่าสิทธิในการใช้งานในระดับใด และมีความสามารถในการเข้าถึงข้อมูลในระดับใดบ้าง จึงยอมให้ไคลเอนต์เข้าใช้งานในไดเรกทอรีเซิร์ฟเวอร์ รูปแบบของการควบคุมการเข้าถึงข้อมูลเราเรียกว่า Access control

Access control model

ได้กำหนดสิทธิของผู้ใช้แบ่งเป็น 3 ระดับ ได้แก่

1. Administrator ในระดับนี้เป็นระดับสำหรับผู้ดูแลระบบสามารถเปลี่ยนแปลงแก้ไขข้อมูลใน Entry ทั้งหมดของไดเรกทอรีเซิร์ฟเวอร์ สามารถที่จะทำการสร้าง แอตทริบิวต์ และ อ็อบเจกต์คลาสขึ้นมาใหม่ได้
2. User ในระดับนี้ยอมให้ผู้ใช้หรือไคลเอนต์ ที่มีสิทธิการใช้งาน 2 รูปแบบคือ
 - 2.1 สามารถทำการอัปเดตข้อมูลส่วนตัวที่ทางผู้บริหารระบบ ยอมให้มีการเปลี่ยนแปลงได้ เช่น เบอร์โทรศัพท์ เปลี่ยนแปลงที่อยู่ ฯลฯ
 - 2.2 ความสามารถในการทำงานแบบ Anonymous ซึ่งจะกล่าวในหัวข้อถัดไป
3. Anonymous ในระดับนี้จะยอมให้ LDAP เครื่องลูกข่าย หรือผู้ใช้สามารถค้นหาข้อมูลในไดเรกทอรีเซิร์ฟเวอร์ตามสิทธิที่กำหนดให้ ไม่สามารถเปลี่ยนแปลงแก้ไขข้อมูลภายใน entry ได้ โดยปกติแล้วการใช้งานแบบ Anonymous ไม่จำเป็นต้องทำการขอสิทธิเข้าใช้งานโดยการ bind

2.4.2 การติดต่อกับโปรโตคอล LDAP ด้วย PHP

PHP มีฟังก์ชันที่ใช้ติดต่อกับโปรโตคอล LDAP ดังตาราง

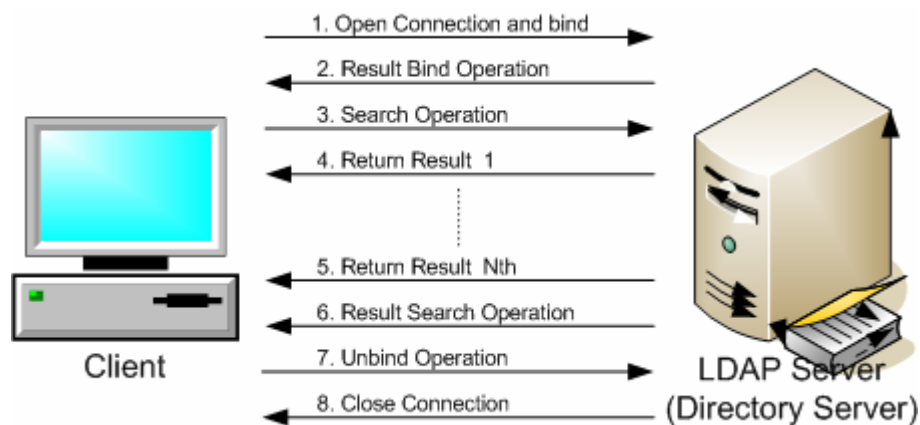
ตารางที่ 2.1 ตัวอย่างฟังก์ชันที่ใช้ติดต่อกับโปรโตคอล LDAP ด้วย PHP

Function	คำอธิบาย
ldap_connect()	ติดต่อกับไดเรกทอรีเซิร์ฟเวอร์
ldap_bind()	พิสูจน์ตัวตนและสิทธิ์กับไดเรกทอรีเซิร์ฟเวอร์
ldap_search()	ค้นหา Entry ในไดเรกทอรี
ldap_unbind()	ตัดSessionการติดต่อ
ldap_add()	สร้าง Entry ในไดเรกทอรี
ldap_delete()	ลบ Entry ในไดเรกทอรี
ldap_modify()	แก้ไขค่าของ Entry ในไดเรกทอรีที่มีอยู่แล้ว
ldap_get_entries()	แสดงค่า Attribute ของ Entry

ขั้นตอนการทำงานของแต่ละคำสั่ง

- จะต้องเริ่มจากการติดต่อกับไดเรกทอรีเซิร์ฟเวอร์ ด้วยคำสั่ง ldap_connect()
- จากนั้นเมื่อติดต่อกับไดเรกทอรีเซิร์ฟเวอร์ ได้แล้วจะทำการพิสูจน์สิทธิ์กับไดเรกทอรีเซิร์ฟเวอร์โดยใช้คำสั่ง ldap_bind()

- ในส่วนนี้เมื่อมีการพิสูจน์สิทธิ์การเข้าถึงไดเรกทอรีเซิร์ฟเวอร์ว่าอยู่ระดับใดแล้วก็สามารถทำการค้นหา, แก้ไขเปลี่ยนแปลงข้อมูลในไดเรกทอรีเซิร์ฟเวอร์ได้ตามระดับสิทธิ์ที่ได้รับ โดยสามารถใช้คำสั่งที่ต้องใช้ข้อมูลของไดเรกทอรีเซิร์ฟเวอร์ได้เช่น `ldap_search()`, `ldap_add()`, `ldap_delete()`, `ldap_modify()`, `ldap_get_entries()`
- จากนั้นเมื่อมีการใช้งาน ไดเรกทอรีเซิร์ฟเวอร์เสร็จเรียบร้อยแล้วจะต้องทำการตัดการเชื่อมต่อกับไดเรกทอรีเซิร์ฟเวอร์ด้วยคำสั่ง `ldap_unbind()` ตามรูป 2.11



รูปที่ 2.11 ตัวอย่างขั้นตอนการทำงานของคำสั่ง Search